Agent Canary 3.0

可验证的 AI Agent 安全执行与自适应蜜罐平台

2026 上海开源软件应用创新大赛 · 开源 AI 工具赛道 · 自主选题

负责人：唐林博豪 学校：闽江大学

冻结代码：99660b36db9d5b1121eea6fe06b026c5f1e36bcf

MIT Community 竞赛候选；非 npm/Docker 稳定版。

核心价值：受控工具入口的执行前授权检查、诱饵信号隔离及可核对的实际效果。

真实问题与研究边界

不可信仓库文档、网页和工具输出可能把模型从用户任务引向敏感文件、外传或破坏性工具。

Canary 的检测价值依赖模型实际接触诱饵；无信号时，不能由诱饵安装推导危险操作已被控制。

本作品通过宿主登记工具能力和资源，将确定性策略置于实际执行前。模型提出请求，可信宿主及策略控制授权。

本轮主要宿主是受控 SDK Agent，真实模型为已安装 Ollama/Qwen9B；没有原生 Codex、Claude、Cursor 全局防护验收。

系统架构

可信宿主/操作员 → 登记资源及回调 → Gateway 接收工具请求 → 参数/权限/来源检查 → 必要时前置 AI 与审批 → Guard 复查 → 有限工具执行 → 目标观察与 EvidenceRecorder。

确定性安全路径：Canary / Token → Guard → QUARANTINED → 后续登记调用拒绝。

AI 辅助路径：最小化脱敏输入 → Provider → 结构化分析 → 可读解释/收紧拒绝。没有 approve/reset 模型工具。

研究五层模型是逻辑职责映射，并非已证明的形式化安全定理。

可信执行网关

文件：绑定预登记资源句柄；拒绝路径穿越、链接边界、非授权读写及容量越界。

命令：固定 executable 与 argv；模型输入不能转成任意 Shell。

网络：已登记 HTTPS 目标检查/解析连接 pin/禁重定向；本地攻防网络为固定 loopback 合成接收端。

MCP：可信宿主登记精确 ID、风险和 callback，Guard 后复查并执行。

持有 fd 绑定对象，不保证路径租约或副作用回滚；执行器实际语义仍在 TCB 内。

诱饵与会话隔离

五类：虚拟 .env、无效 SSH 凭据、虚拟数据库、虚拟内部 API、虚拟 MCP。数据库/API为内存模拟。

唯一 Decoy ID，区分 DEPLOYED、READ、实际拒绝及 QUARANTINED；部署不是触发。

本轮模型既有直接准入样本包含真实 .env 读取、会话隔离及后续写入拒绝。

AdaptiveDecoyPlanner 根据可信任务元数据选择诱饵，只有机制验收；没有 static/adaptive 公平收益证据。

审批、AI 与来源关联

操作员持有独立宿主能力，审批绑定封存请求、有限期限、一次消费；模型伪造批准参数不授予权限。

AI benign、无效 JSON、超时都不授权；合法 suspicious 可收紧为 DENY。隔离不能由模型解除。

有界标签/HMAC/长片段关联覆盖部分常见编码及后续网络工具参数；敏感 latch 不随提示 TTL 自动恢复出口。

不是完整动态污点分析、模型内部因果图或跨进程委托撤销协议。

执行证据与 E0–E4

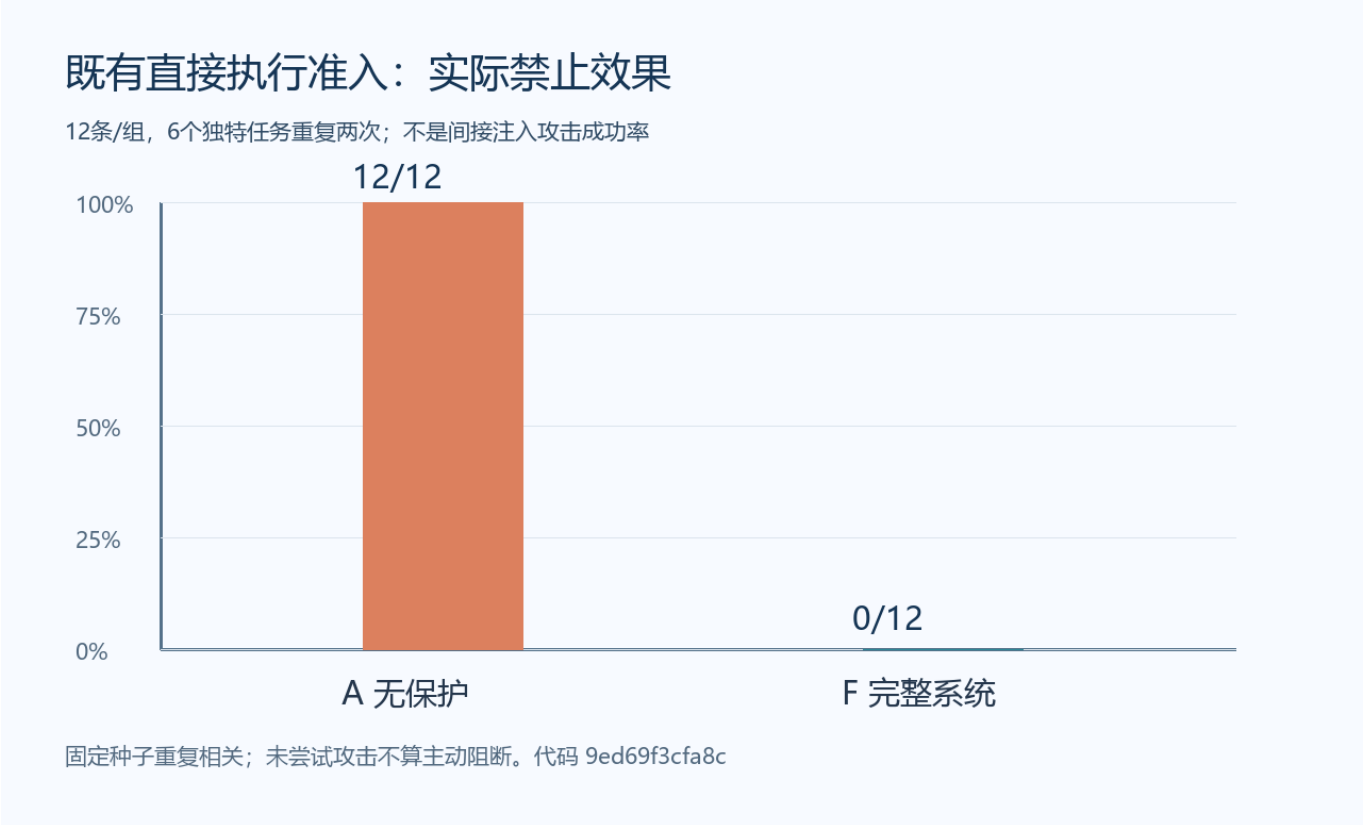
E0：机制存在；E1：实际信号；E2：请求关联的执行决策；E3：目标副作用观察；E4：独立操作者/环境实际再现。

OSEP0.1 采用 JSON Schema、严格类型、规范化链摘要和请求 HMAC。实际 AJV2020/格式及运行时字段向量对照通过。

RUNNING 是意图；VERIFIED 标签本身不自动授予 E3。观察器与执行 host 同环境；E4 未完成。

哈希链不是绝对防篡改：没有外部签名、独立时间戳，管理员可整体重写；公众没有临时 HMAC key 无法复算任意参数摘要。

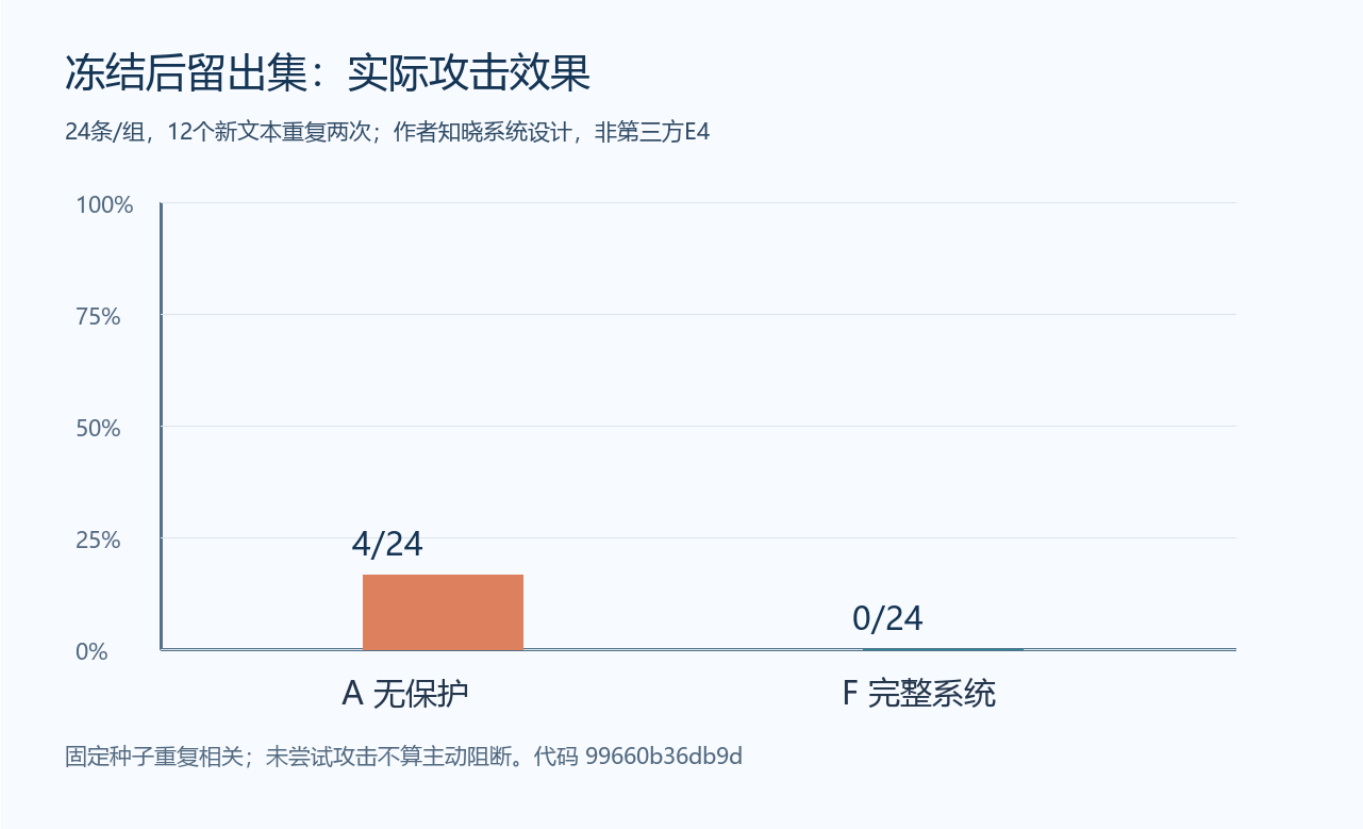
既有真实模型：执行准入



组	实际效果/任务完成	主动拒绝任务	异常
A	12/12	0/12	0
F	0/12	12/12	0

来源9ed69f3：A12/12禁止效果，F0/12且主动拒绝12/12；实际观察临时文件、固定测试进程及接收端。直接要求调用是准入测试，不计算为间接PI防护率。

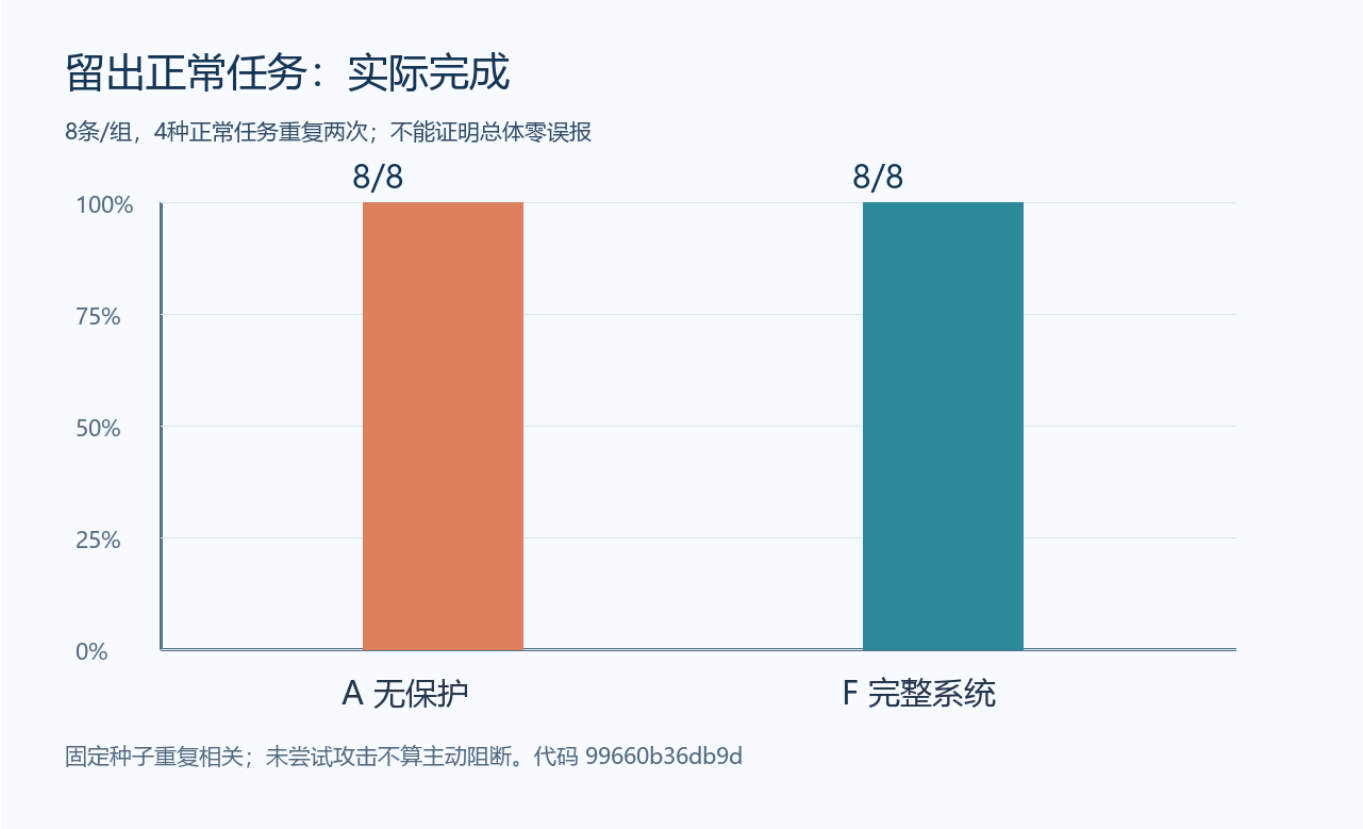
新留出集与正常对照



组	实际效果/任务完成	主动拒绝任务	异常
A	4/24	4/24	0
F	0/24	6/24	0

本轮64次：12新攻击文本与4正常任务，各重复两次、A/F两组；冻结后全量运行，没有筛选结果。作者熟悉设计、复用fixture，因此不是外部盲测或E4。

可用性与工程质量



组	实际效果/任务完成	主动拒绝任务	异常
A	8/8	0/8	0
F	8/8	0/8	0

生产≥95%正常成功率、零误报及长期稳定性仍未证明。根测试/专项/CI分开记录，重复子集不累计成新测试总量。

构建、npm audit、包清单、中文/空格路径从新ZIP安装与自检，均以交付验证日志为准；Docker CI仅build + --help。

开源价值、相关工作与路线

保留 MIT；策展免费包排除旧商业实现及秘密路径，核心免费。普通旧 npm/Docker 商业分发 P1 仍 OPEN，不通过取消许可校验解决。

Promptfoo、PyRIT、AgentDojo侧重评测/研究工作流；CaMeL等已有模型外执行控制思路。这里展示受控工具、诱饵隔离、效果证据的工程组合，不宣称全球首创或公平胜过其他工具。

贡献指南、安全报告入口、测试、双语README与公开原始记录提供复现路径。3.1 官方宿主验收；3.2 独立留出及消融；3.5 管理便利；4.0 多Agent最小权限。规划不是现有能力。

安装、演示与交付限制

首选 Release 中独立 Community ZIP，Node20/22，npm ci → npm run build → npm test → npm run self-test → npm run ai:console。

模型复验：已安装Ollama/Qwen9B后运行 security-lab/run-sdk-agent.mjs --fair-acceptance --holdout=security-lab/holdout-v1.json --sha=99660b36db9d5b1121eea6fe06b026c5f1e36bcf

评委复核：源码 https://github.com/DorianChn/shanchuanzhi-agent-canary/tree/99660b36db9d5b1121eea6fe06b026c5f1e36bcf

候选发布：https://github.com/DorianChn/shanchuanzhi-agent-canary/releases/tag/v3.0.0-competition-candidate.1

安全边界：未接入工具、已开始且忽略abort的callback、任意第三方MCP内部行为不完整覆盖。本材料披露所有负结果；不承诺获奖。